Ethical hacking and defense

Offline Password Cracking Attacks

Objectif :

L'objectif de ce TP est de vous introduire certains aspects d'audit de la sécurité informatique. Au niveau de la distribution Kali Linux, nous allons utiliser : - Password Cracking – John Ripper;

ATTENTION :

Ce travail montre certaines techniques de base pouvant être utilisées pour commettre des actes illégaux. Ceci est jugé utile dans le cadre du cours pour permettre de mieux connaître les attaques pouvant être faites sur les systèmes qu'on veut protéger, **MAIS il ne faut pas appliquer ces tests sur des systèmes réels sans autorisation écrite.**

1. John the Ripper

Les mots de passe sont des mécanismes de sécurité très important. Pourtant, les mots de passe restent vulnérables à de nombreuses attaques, principalement parce que les utilisateurs sont incapables de mémoriser des chaînes de caractères longues et complexes. Les utilisateurs ont tendance à choisir des mots de passe simples en fonction des noms et des mots du dictionnaire.

a. Description de l'attaque

Dans ce TP, nous allons utiliser des craqueurs de mots de passe pour effectuer des attaques hors ligne sur des mots de passe. Une attaque hors ligne signifie que l'attaquant a accès aux mots de passe "protégés" et peut donc essayer de trouver les mots de passe à sa guise. . Il ne s'agit pas d'une attaque en ligne, où l'attaquant est limité par le nombre de tentatives autorisées (généralement 3). Dans cette section, nous utiliserons John the Ripper, un outil de craquage de mots de passe.

b. Téléchargement des mots de passes et préparation de l'environnement d'attaque

Créer un dossier LAB6 et télécharger John the Ripper :

```
$ mkdir LAB6
$ cd LAB6
$ wget www.openwall.com/john/j/john-1.8.0.tar.xz
$ tar -xv f john-1.8.0.tar.xz
```

Téléchargez crack-these-please depuis ***https://www.dropbox.com/s/3or7x52xb35kvau/crack-these-please?dl=0*** (utilisez un navigateur web pour le téléchargement). Mettez le fichier ***crack-theseplease*** sous le répertoire ***john-1.8.0/run***. Ce fichier crack-theseplease.txt contient les mots de passe de 50 utilisateurs, avec les noms crack01 à

crack50. Les mots de passe sont variés, certains choisis pour être simples et faciles et d'autres complexes et difficiles.

c. Dictionary attack

Une attaque par dictionnaire utilise une base de données de mots, et l'essaie à plusieurs reprises. John l'éventreur a cette capacité. Affichez le contenu de password.lst à l'écran en donnant la commande :

$ more password.lst

Appuyez sur la barre d'espacement, ou maintenez-la enfoncée, pour faire avancer l'affichage jusqu'à la fin du fichier. Vous voyez qu'il s'agit d'une liste de mots de passe potentiels. Il y en a environ 3000. Des dictionnaires plus importants sont disponibles sur ***Internet http://www.openwall.com/wordlists/.*** De plus, dans la vie réelle, si vous avez des informations personnelles sur les utilisateurs, vous devriez les inclure dans le dictionnaire.

$ cd john −1.8.0/run
$ john --wordlist=password.lst crack-these-please

d. Hybrid attack

Une attaque hybride vérifie les variations d'un mot ou d'une combinaison de mots du dictionnaire. Lancez une attaque hybride en exécutant :

$ enable substitution rules
$ john --wordlist=password.lst --rules crack-these-please

e. Conbination attack :

Par défaut, John the Ripper exécute des attaques par dictionnaire, hybrides et de force brute en combinaison. Lancez une attaque combinée en exécutant :

$ john crack−these-please

Laissez John fonctionner assez longtemps pour faire d'autres craquements. Notez le temps qu'il a pris et combien de mots de passe supplémentaires qu'il a pu craquer. Notez également la nature des mots de passe. Quelle proportion des mots de passe crackés peuvent être trouvés dans le dictionnaire ? Et dans un dictionnaire de langue étrangère ? Combien de ces mots de passe contiennent des combinaisons variées de lettres, symboles, chiffres et de casse ? Les mots de passe crackés ont-ils tendance à être longs ou courts ? Obtenir tous les mots de passe pourrait prendre une éternité, donc si cela prend trop de temps, vous pouvez appuyer sur CTRL-C pour arrêter l'exécution.

f. Test de l'attaque sur le système UNIX :

Au niveau de la session root, créez un utilisateur normal (user1 et user2 par exemple) en utilisant la commande commande "useradd".

$ useradd user2
$ useradd -c "User" -s /bin/bash -m -g users -k /etc/skel-comm -b /home/ user1

Attribuez des mots de passe aux utilisateurs. En utilisant la commande "su", connectezvous en tant que ces utilisateurs :

$ passwd user1
$ passwd -n 60 -x 90 -w 7 user2
$ su user1

Sur un terminal, affichez le contenu des fichiers "/etc/shadow" et "/etc/passwords". Expliquez le rôle de ces fichiers.

$ more /etc/shadow
$ more /etc/passwords

Nous allons utiliser l'utilitaire "unshadow" de John pour obtenir le format classique d'un fichier de mot de passe sous linux :

$ unshadow /etc/passwd /etc/shadow > mypasswd

Nous lançons John the Ripper pour essayer de trouver les mots de passe des utilisateurs ciblés, en utilisant la commande suivante :

$ john - -format=crypt mypasswd

Vous pouvez utiliser un dictionnaire pour craquer les mots de passe des fichiers */etc/shadow* :

$ john - --wordlist=password.lst. --format=crypt --rules mypasswd